



CVE-2025-20337: CRITICAL CISCO ISE FLAW ALLOWING UNAUTHENTICATED ATTACKERS TO EXECUTE ROOT CODE

Vairav CVE Report

Date: July 17, 2025

Vairav Cyber Threat Intelligence Team

Vairav Technology Security Pvt. Ltd.

Thirbam Sadak 148

Baluwatar, Kathmandu

Phone: +977 4541540

Mobile: +977-9820105900

Email: sales@vairavtech.com

EXECUTIVE SUMMARY

A critical, unauthenticated remote code execution (RCE) vulnerability—**CVE-2025-20337**—affects Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC). The flaw allows an attacker to submit a specially crafted API request and achieve arbitrary code execution on the underlying OS **as root**, without any credentials. It carries a **CVSS score of 10.0 (Critical)**. Successful exploitation could lead to full system compromise, lateral movement within a network, and data exfiltration.

VULNERABILITY DETAILS

CVE-2025-20337

- **Description:** A flaw in a specific unauthenticated API of Cisco ISE/ISE-PIC permits remote attackers to perform arbitrary command execution. The root cause is insufficient validation of user-supplied input. Attackers can exploit this by sending crafted API requests, triggering shell-level execution with root privileges.
- **Impact:** Unauthenticated attackers gain root access to the device, enabling full control of the system, installation of malware, credential harvesting, or pivoting into internal networks.
- **CVSS Score:** 10.0 (Critical)

AFFECTED VERSIONS

The following Cisco ISE and ISE-PIC releases are affected:

- Cisco ISE or ISE-PIC Release 3.3
- Cisco ISE or ISE-PIC Release 3.4

EXPLOIT DETAILS

These vulnerabilities target networks where Cisco ISE or ISE-PIC is used as an authentication, profiling, or network access control service. An attacker needs only network reachability to the affected API endpoint—no credentials required—to exploit the flaw. In a real-world scenario, exploitation could allow immediate takeover of authentication servers, disabling of access controls, deployment of persistent malware, or lateral

movement deeper into the corporate network. According to Tenable, exploits already exist and are relatively easy to deploy

RECOMMENDED ACTIONS

Patch & Upgrade: Upgrade Cisco ISE and ISE-PIC to versions with the fix:

- **Cisco ISE or ISE-PIC 3.3 Patch 7** or later
- **Cisco ISE or ISE-PIC 3.4 Patch 2** or later

ADDITIONAL SECURITY MEASURES

- **Host-level hardening:** Enforce strong OS-level controls, restrict execution rights, and apply patching.
- **Network monitoring:** Deploy IDS/IPS with signatures detecting anomalous API calls to Cisco ISE.
- **Incident readiness:** Prepare emergency backup/restore plans and ensure access to out-of-band admin consoles in the event of compromise.

REFERENCES

- <https://thehackernews.com/2025/07/cisco-warns-of-critical-ise-flaw.html>
- <https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-ise-unauth-rce-ZAd2GnJ6>

CONTACT US

Vairav Technology Security Pvt. Ltd.

Cyber Defender from the land of Gurkha

Thirbam Sadak 148, Baluwatar

Kathmandu, Nepal

Phone: +977-01-4541540

Mobile: +977-9820105900

Email: sales@vairavtech.com

Website: <https://vairavtech.com>